

第四章 数据库安全性 — 选择题解析

第 1 题

答案：C

解析：

这题考的是 CASCADE 级联回收的范围。

理清 U2 获得权限的两条路径：

- 路径一：DBA → U1 (带 WITH GRANT OPTION) → U2 (U1 转授的)
- 路径二：DBA → U2 (DBA 直接授的)

操作④ REVOKE ... FROM U1 CASCADE 会沿着"U1 传播出去"的路径回收，也就是把路径一回收掉。但路径二来自 DBA 直接授权，和 U1 无关，不受影响。

所以 U2 仍然保留 SELECT 权限——靠的是 DBA 直接给的那条。

A 的结论对 ("是")，但理由说"不受 U1 被回收的影响"太绝对，U2 通过 U1 的那条权限确实被回收了。C 更准确：CASCADE 只回收 U1 传播的权限，DBA 直接给的那条还在。

B 错：CASCADE 不是把 U2 的所有权限都回收，只回收 U1 传播的那条。

D 错：U2 不依赖 U1，DBA 直接给了。

记住：一个权限可以有多条授权路径，回收一条不影响其他路径。CASCADE 只砍"被回收者传播出去的树枝"。

第 2 题

答案：B

解析：

- DAC (自主存取控制)：用户可以自由把权限转授给别人。灵活但容易失控。
- MAC (强制存取控制)：安全标记由系统/安全管理员统一分配，用户不能自行改变。严格但死板。

A 错：DAC 能自由传播恰恰是不安全的因素，不是更安全。

B 正确：MAC 中用户不能改标记，适合军事等严格控制场景。

C 错：MAC 优先级高于 DAC，二者同时用时 MAC 先检查。

D 错：MAC 同样适用于数据库 (本题第 7 题就是数据库里的 MAC)。

一句话：DAC 像"你自己决定借不借书给别人"，MAC 像"图书馆规定这本书几级读者能借，你说了不算"。

第 3 题

答案：A

解析：

A 正确：GRANT ALL PRIVILEGES ON TABLE Student TO PUBLIC 是标准语法——把 Student 表的所有权限授予所有用户 (PUBLIC)。

B 错：INSERT 权限在教材口径下是表级的，不细分到列。列级权限主要用于 SELECT 和 UPDATE。



C 错：SELECT 是对象权限，授权时用 WITH GRANT OPTION；WITH ADMIN OPTION 是给角色授权时用的，张冠李戴。

D 语法本身也合法（PUBLIC 可作为 REVOKE 的对象），本题存在 A、D 双正确答案的瑕疵。A 更能体现 GRANT ALL PRIVILEGES ... TO PUBLIC 的标准授权写法，故标准答案为 A。

区分两个 OPTION：WITH GRANT OPTION 搭配对象权限，WITH ADMIN OPTION 搭配角色。记反了就掉坑。

第 4 题

答案：B

解析：

U1 把角色 R1 授予 U2，U2 获得的是"角色 R1 本身"这个身份，而不是某个具体权限的副本。

A 错：U2 不只是拥有 SELECT，而是拥有 R1 包含的所有权限——以后 R1 加权限，U2 自动跟着有。

B 正确：U2 拥有角色 R1 本身，可行使 R1 的全部权限，且 R1 变化时自动更新。

C 错：WITH ADMIN OPTION 要 U1 授权时显式指定才传给 U2，不会自动获得。

D 错：角色权限变化时，U2 的权限会自动更新——这正是角色的好处。

角色就像"会员卡"。U2 办了 R1 会员卡，R1 今天含 SELECT，明天加了 UPDATE，U2 自动享受 UPDATE——不用重新办卡。

第 5 题

答案：B

解析：

A 错：视图不能替代 GRANT/REVOKE，二者配合才能实现完整安全控制。

B 正确：视图隐藏敏感列（比如不暴露工资列），再 GRANT 视图的 SELECT 权限，用户只能通过视图看到允许的列——这就是列级安全。

C 错：视图可以用于插入和修改（满足条件时），不是只能查。

D 错：WITH CHECK OPTION 是防止"通过视图插入/修改出视图范围外的数据"，不是防止看到敏感数据。

视图 = 给表戴个面具，只露出该露的列。WITH CHECK OPTION = 防止你隔着面具偷偷改面具外面的东西。

第 6 题

答案：C

解析：

审计（Audit）的本质是事后记录，不是事前拦截。

A 正确：审计可以记录所有操作。

B 正确：审计用于事后追查责任人。

C 错误：审计不能实时阻止非法操作——那是存取控制（GRANT/REVOKE、MAC）干的事。审计只能"记录在案"，事后追责。

D 正确：审计确实消耗资源、影响性能。

题目问"错误的是"，所以选 C。

审计 = 监控摄像头。它能录下小偷作案全过程用于事后追查，但不能在作案当下伸手拦住小偷。能



拦的是保安（存取控制）。

第 7 题

答案：B

解析：

MAC 的核心规则——向下读：用户的许可证级别 $\geq$ 数据的密级，才能读。

四个等级从高到低：绝密 $>$ 机密 $>$ 秘密 $>$ 公开。

用户许可证是“机密”，能读的数据密级必须 $\leq$ 机密，即：机密、秘密、公开。

- 绝密读不了（密级高于许可证）
- 机密
- 秘密
- 公开

所以选 B。

A 错：绝密高于机密，读不了。

C 错：不能读所有级别，绝密读不了。

D 错：不是只能读同级，比自己低的也能读。

记住口诀：只能往下看，不能往上看。你是机密级，绝密的事你无权知道。

>

补充：MAC 还有对称的向上写规则——只能往等于或高于自己许可证级别的客体写，防止高密级数据流向低密级主体。

第 8 题

答案：C

解析：

A 错：说反了。WITH GRANT OPTION 用于对象权限（表、视图等），WITH ADMIN OPTION 用于角色。

B 错：WITH GRANT OPTION 回收时可以用 CASCADE 或 RESTRICT——RESTRICT 表示若权限已被转授则拒绝回收并报错，CASCADE 则级联清理。不是只能 CASCADE。

C 正确：WITH ADMIN OPTION 在回收角色时不级联——U1 把角色给了 U2，U2 又给了 U3，回收 U1 的角色不会自动回收 U2、U3 的角色（和对象权限的 CASCADE 机制不同）。

D 错：两者用途不同，不能互换。

对象权限用 GRANT OPTION，回收会级联（砍树枝）；角色用 ADMIN OPTION，回收不级联（各管各的）。这是两者的关键区别。

第 9 题

答案：C

解析：

三个系统权限的能力范围：

- DBA：最高，能创建用户、建库、授权……啥都能干
- RESOURCE：能创建基本表、视图，能把自己的表权限授予别人
- CONNECT：最基础，只能连数据库，不能建表



U2 拥有的是 RESOURCE 权限。

A: 创建基本表 Student —— RESOURCE 可以

B: 创建视图 CS_Student —— RESOURCE 可以

C: 创建新用户 U4 —— 需要 DBA 权限, U2 没有 → 选 C

D: 把 Student 表的 SELECT 授予 U3 —— Student 是 U2 自己建的表, 表主可以授权

创建用户是 DBA 的专属权力, RESOURCE 再强也建不了用户。就像普通店长能进货能上架, 但开新分店得老板批。

第 10 题

答案: C

解析:

A 错: 加密不替代身份鉴别, 二者是不同层级的安全措施。

B 错: 加密不替代存取控制, 存取控制管"谁能访问", 加密管"即使拿到也看不懂"。

C 正确: 加密是最后一道防线——假设前面所有防线都被突破, 数据被偷走了, 但偷走的是密文, 没有密钥就是一堆乱码。

D 错: 加密会降低性能(加解密开销), 不是提高。

安全的层次: 身份鉴别(你是谁) → 存取控制(你能干啥) → 视图(只给你看该看的) → 审计(记下你干了啥) → 加密(就算偷走了也看不懂)。加密兜底, 最后防线。

答案汇总

1.C 2.B 3.A 4.B 5.B 6.C 7.B 8.C 9.C 10.C

